

Trabajo en clase

Integrantes: Lesly Becerra, Maiccol Zurita, Alan Velasco, Anderson Soto

Nota. Ejecutamos el comando `sudo msfconsole` en el sistema operativo Kali Linux bajo el usuario alan. Así se despliega el entorno interactivo de Metasploit Framework con privilegios elevados (root) para preparar la fase de escaneo y luego explotar las vulnerabilidades en la red interna.

Nota. Identificamos las advertencias para configurar variables inválidas en el escáner, y seleccionamos el exploit definitivo `ms17_010_eternalblue` para habilitar el ataque. Luego establecimos correctamente los valores críticos del entorno asignando la IP de la víctima en `RHOSTS`, la IP de Kali Linux en `LHOST` y el payload de control interactivo `windows/x64/meterpreter/reverse_tcp`, dejando la intrusión lista para ejecutarse.

Nota. Ejecución exitosa del exploit EternalBlue (`ms17_010_eternalblue`) contra la máquina objetivo. El sistema valida automáticamente la vulnerabilidad en el puerto 445 e inyecta el payload en la memoria del sistema operativo Windows 7. Al completarse la inyección de código, se logra burlar la seguridad del host y se abren con éxito las sesiones interactivas de control remoto Meterpreter session 1 y session 2, otorgando acceso total e inmediato al equipo auditado.

Nota. Se ven los intentos de enumerar los usuarios del sistema mediante el módulo de post-explotación `enum_logged_on_users` dentro de la sesión de Meterpreter. El proceso es interrumpido de forma inesperada debido a la inestabilidad que el exploit genera en la memoria RAM del equipo de la víctima. Al final, se documenta la caída simultánea y el cierre de las sesiones de control interactivo session 1 y session 2 (Reason: Died), reflejando la desconexión total del host.

Nota. Esta es la fase final de descifrado de credenciales mediante ataques de fuerza bruta en una terminal local de Kali Linux. Exportamos el hash NTLM del usuario objetivo al archivo `zaid_hash.txt`. Inicializamos la herramienta Hashcat configurando el modo de ataque 1000 específico para contraseñas de Windows y utilizando el diccionario de palabras `rockyou.txt` para procesar el hash capturado mediante el hardware del sistema.

Nota. Final del ataque de fuerza bruta con la obtención de la contraseña en texto plano. Hashcat marca el estado del proceso como Cracked luego de ver eficientemente el hash NTLM contra el diccionario de palabras. El sistema revela de forma fidedigna que la clave del usuario Zaid corresponde exactamente a la cadena numérica 12345, confirmando la existencia de una política de contraseñas sumamente débil y vulnerable dentro de la organización.

Diccionario: rockyou.txt

Ruta nativa: /usr/share/wordlists/rockyou.txt